Sisältö

1. Säädökset FI – EU sääntely
2. EUn Kyberkestävyyssäädös (Cyber Resilience Act, CRA)
3. IEC 62443 standardisarja ja kyberturva
4. SBOM (Software Bill Of Materials)

Lain tulkinnan lähteet

1. **Tuomioistuinta vahvasti velvoittavat**
   (tuomarin noudatettava, mikäli säännös on selkeä)

   a) Eduskunnan säätämä laki tai asetus
   b) Suoraan EUsta tuleva asetus

2. **Tuomioistuinta heikosti velvoittavat**

   a) Hallituksen esitys (lain valmistelu)
   b) Tuomioistuinkäytäntö (ennakkopäätös)

3. **Sallitut oikeuslähteet**

   a) Oikeuskirjallisuus
   b) Muut oikeusjärjestykset

Siviilituomio-istuimet

Käräjäoikeus (KäO)

Hovioikeus (HO)

Korkein oikeus (KKO)

Aluehallintoviraston (AVI) päätös

Hallintotuomio-istuimet

Hallinto-oikeus (HaO)

Korkein hallinto-oikeus (KHO)

Säädösten tulkinnan lähteet

Tuomioistuinta vahvasti velvoittavat
(tuomarin noudatettava, mikäli säädös on selkeä)

1. Eduskunnan säätämä laki tai asetus

EUn Directiivi

Network and Information Security Directive (**NIS 2**) - Euroopan unionin kyberturvallisuusdirektiivi (EU 2022/2555)

↓

Hallituksen esitys eduskunnalle kyberturvallisuusdirektiivin (NIS 2 -direktiivi) täytäntöönpanoa koskevaksi lainsäädännöksi (HE 57/2024)

↓

Kyberturvallisuuslaki (124/2025)

2. Suoraan EUsta sovellettavaksi tuleva asetus

EUn Asetus

Cyber Resilience Act (CRA) - Kyberkestävyyssäädös

Hallituksen esitys eduskunnalle kyberkestävyysasetuksen toimeenpanoa koskevaksi lainsäädännöksi (kansalllinen täydentäminen)

Juridisen tekstin viittaustekniikka

Kyberturvallisuuslaki **(124/2025) (NIS2)** - finlex.fi

1 luku - Yleiset säännökset

1 § - Soveltamisala

2 § - Määritelmät

3 § - Toimijat

4 § - Soveltamisalan rajaukset

5 § - Suhde muuhun lainsäädäntöön

6 § - Lainkäyttövalta ja alueellisuus

2 luku - Riskienhallinta ja poikkeamista ilmoittaminen

7 § - Riskienhallinta

8 § - Kyberturvallisuutta koskeva riskienhallinnan toimintamalli

9 § - Toimenpiteet

3 §:n 2 momentin 4 kohta
3 § 2 momentti kohta 4
Luku 1 pykälä 3 momentti 2 kohta 4
pykälä 3 momentti 2 kohta 4
3 § 2 mom. kohta 4
3.2 § kohta 4
1:3.2 kohta 4

3 §
Toimijat

1 Tätä lakia sovelletaan oikeushenkilöön ja luonnolliseen henkilöön (*toimija*), joka:

1) harjoittaa liitteessä I tai II tarkoitettua toimintaa tai on mainituissa liitteissä tarkoitettu toimija; ja

2) täyttää tai ylittää mikroyritysten sekä pienten ja keskisuurten yritysten määritelmästä annetun komission suosituksen 2003/361/EY liitteen 2 artiklan mukaiset keskisuuria yrityksiä koskevat edellytykset ja tarjoaa palvelujaan tai harjoittaa toimintaansa jossakin Euroopan unionin jäsenvaltiossa.

2 Tätä lakia sovelletaan myös toimijaan, joka koostaan riippumatta on:

1) yleisten sähköisten viestintäverkkojen tai yleisesti saatavilla olevien sähköisten viestintäpalvelujen tarjoaja;

2) luottamuspalvelun tarjoaja;

3) aluetunnusrekisterin ylläpitäjä; tai

4) DNS-palveluntarjoaja.

Harjoitus

NIS2 → Kyberturvallisuuslaki (124/2025)

1. **Etsi kyberturvalaki**
2. **Mene kohtaan 3 §:n 1 momentin 2 kohta**
3. **Selvitä miten määritetään mikro / pieni / keskisuuri yritys ?**

Lakia sovelletaan ....

3 §
Toimijat

Tätä lakia sovelletaan oikeushenkilöön ja luonnolliseen henkilöön (*toimija*), joka:

1) harjoittaa liitteessä I tai II tarkoitettua toimintaa tai on mainituissa liitteissä tarkoitettu toimija; ja

2) täyttää tai ylittää mikroyritysten sekä pienten ja keskisuurten yritysten määritelmästä annetun komission suosituksen 2003/361/EY liitteen 2 artiklan mukaiset keskisuuria yrityksiä koskevat edellytykset ja tarjoaa palvelujaan tai harjoittaa toimintaansa jossakin Euroopan unionin jäsenvaltiossa.

Vihje

Mistä etsitään ?

- Kyberturvallisuusdirektiivi (NIS2)
- komission suositus 2003/361/EY
- Tuomioistuinratkaisut (korkein oikeus, korkein hallinto-oikeus)
- Hallituksen esitys eduskunnalle
- Kyberturvallisuuslaki (finlex.fi)
- Muualta

Harjoituksen eräs ratkaisu

Lainsäädäntö

Ajantasaistettu lainsäädäntö ja Suomen säädöskokoelma

Perushaku | Etäisyyshaku | Laajennettu haku

124/2025 [Hae]

LAINSÄÄDÄNTÖ

124/2025

Finlex > Lainsäädäntö > 2025 > 124

Ajantasaistettu lainsäädäntö

Ajantasaistetut säädöstekstit, joissa säädöksiin tehdyt muutokset sisältyvät säädöstekstiin

Sisällysluettelo

1 luku - Yleiset säännökset
1 § - Soveltamisala
2 § - Määritelmät
3 § - Toimijat
Kyberkriisinhallintaviranomainen
45 § - Viranomaisten yhteistyö
46 § - Muutoksenhaku
47 § - Voimaantulo
Liite I
Liite II
Muutossäädösten voimaantulo ja soveltaminen
27.6.2025/369:
27.6.2025/494:
27.6.2025/698:
14.11.2025/997:

Kyberturvallisuuslaki [Ajantasainen]

Kieliversiot	Suomi, Ruotsi [Vertaile]
Säädöksen tyyppi	Laki
Hallinnonala	Liikenne- ja viestintäministeriö
Antopäivä	4.4.2025
Julkaisupäivä	7.4.2025

27.6.2025/494:

Tämä laki tulee voimaan 1 päivänä tammikuuta 2026.

HE 5/2025, LaVM 6/2025, EV 52/2025

Uusina organisaatioina kyberturvallisuuslain soveltamisalaan voisi tulla kriittiseksi määritetty yritys tai yhteisö, joka on kooltaan pien- tai mikroyritys, taikka harjoittaa sellaista toimintaa, joka ei kuulu NIS 2 -direktiivin liitteisiin, mutta kuuluu CER-direktiivin liitteisiin. Pien- tai mikroyrityksiä ovat komission suosituksen 2003/361/EY liitteen 2 artiklan nojalla yritykset, joiden palveluksessa on vähemmän kuin 50 työntekijää ja jonka vuosiliikevaihto tai taseen loppusumma on enintään 10 miljoonaa euroa. CER-direktiivin liitteisiin kuuluvat toimialat, jotka eivät kuulu NIS 2 -direktiivin liitteisiin, ovat julkinen liikenne ja lääketukkukaupat.

Sisältö

1. Säädökset FI – EU sääntely
2. EUn Kyberkestävyyssäädös (Cyber Resilience Act, CRA)
3. IEC 62443 standardisarja ja kyberturva
4. SBOM (Software Bill Of Materials)

Kyberkestävyyssäädös (CRA, Cyber Resilience Act)

VARMISTAA VERKKOON LIITETTYJEN LAITTEIDEN JA OHJELMISTOJEN KYBERTURVALLISUUS

Soveltamisala, Artikla 2
Tätä asetusta sovelletaan **kaikkiin** markkinoilla saataville asetettuihin digitaalisia elementtejä sisältäviin tuotteisiin, joiden käyttötarkoitus tai kohtuudella ennakoitavissa oleva käyttö sisältää suoran tai välillisen loogisen tai *fyysisen datayhteyden johonkin laitteeseen tai verkkoon*.

9/2026 Haavoittuvuuksien raportointivelvollisuus (artikla 14)

a) Valmistajan on ilmoitettava kaikista digitaalisia elementtejä sisältävään tuotteeseen sisältyvistä ***aktiivisesti hyödynnetyistä haavoittuvuuksista***, joista se on tullut tietoiseksi
   → ”***aktiivisesti hyödynnetyllä haavoittuvuudella***” tarkoitetaan haavoittuvuutta, jonka osalta on luotettavaa näyttöä siitä, että jokin pahantahtoinen toimija on hyödyntänyt sitä järjestelmässä ilman järjestelmän omistajan lupaa;”
   → 24 h ennakkovaroitusilmoitus → CSIRT ja ENISA

b) Valmistajan on ilmoitettava kaikista digitaalisia elementtejä sisältävän tuotteen tietoturvaan vaikuttavista ***vakavista poikkeamista***, joista se on tullut tietoiseksi
   → 72 h haavoittuvuusilmoitus → CSIRT ja ENISA

Valmistajien velvollisuudet (artikla 13)

- Tuotteen valmistajien on varmistettava, että tuote on *suunniteltu, kehitetty ja tuotettu* Kyberkestävyyssäädöksen *olennaisten kyberturvallisuusvaatimusten* mukaisesti → **Liite I**
- Tuotteen CE-merkintä kertoo kyberturvallisuusvaatimuksista
- Olennaiset kyberturvallisuusvaatimukset toteutetaan **riskiperusteisesti**
  - Turvalliset oletusasetukset ja automaattiset turvallisuuspäivitykset
  - Luvattomalta pääsyltä estäminen
  - Datan luottamuksellinen säilyttäminen ja datan minimointi
  - Keskeisten toimintojen turvaaminen

Liite I Olennaiset kyberturvallisuusvaatimukset

Osa I tuotteiden ominaisuuksiin liittyvät kyberturvallisuusvaatimukset

1) Turvallisuuden huomioiminen alusta alkaen ja rakentaminen sisään tuotteeseen sen koko elinkaaren ajaksi → **SDL**
2) a) ei tunnettuja hyväksikäytettäviä haavoittuvuuksia julkaisun hetkellä
   b) Turvallinen oletuskonfiguraatio ja palautus alkuasetuksiin (secure by default)
   d) Varmistaa, että tuote on suojattu luvattomalta käytöltä

Osa II Haavoittuvuuksien käsittelyä koskevat vaatimukset

1) Komponenttien ja haavoittuvuuksien dokumentointi
4) Haavoittuvuuksien julkistaminen ja tiedottaminen
7) Tietoturvapäivitysten turvallinen ja maksuton jakelu

CRA – MITÄ PITÄÄ TEHDÄ ?

TRAFICOM
Liikenne- ja viestintävirasto
Kyberturvallisuuskeskus

Muistio 1 (7)

18.11.2025

CRA valmistajan velvoitteet ja ENISAN kartoitusdokumenttiin perustuvat suuntaa antavat vaatimukset

Tässä dokumentissa kuvataan CRA:n velvoitteet valmistajille, CRA:n vaatimuskohdat ja suuntaa antavat ulkoiset vaatimukset, jotka on koostettu ENISA Cyber Resilience Act Requirements Standards Mapping pohjalta: Cyber Resilience Act Requirements Standards Mapping - final_with_identifiers_0.pdf. Liikenne- ja viestintävirasto toteaa selvyyden vuoksi, että tämä kooste ei ole kattava listaus vaatimuksista vaan tarkoitus on neuvoa ylätasolla tämänhetkisestä tilanteesta. Oikeudellisesti sitovat velvoitteet säädetään asetuksessa, komission täytäntöönpanosäädöksissä sekä yhdenmukaistetuissa standardeissa ja teknisissä eritelmissä.

Ohjelmistokehitys		**Suuntaa antava ulkoinen vaatimus (ENISA Cyber Resilience Act Requirements Standards Mapping); Työn alla olevat harmonisoidut standardit täydentävät**
Valmistaja	**CRA:n kohta**	
Turvallisuuden huomioiminen alusta alkaen ja rakentaminen sisään tuotteeseen sen koko elinkaaren ajaksi.	Liite I, Osa I: 1) | Digitaalisia elementtejä sisältävät tuotteet on suunniteltava, kehitettävä ja tuotettava siten, että niiden kyberturvallisuuden taso on oikeassa suhteessa riskeihin.	EN ISO/IEC 27001:2022 (ISMS) EN ISO/IEC 27002:2022 (tietoturvakontrollit) EN ISO/IEC 27005:2022 (riskienhallinta) EN IEC 62443-4-1:2018 (Secure product development lifecycle) EN IEC 62443-3-2:2020 (Risk assessment IACS)

IEC 62443 – MITEN KANNATTAISI TEHDÄ ?

OT-ympäristö

- **IEC 62443-4-1:2018** (Secure product development lifecycle - **SDL**)
- **IEC 62443-4-2:2019** (Technical security requirements for **IACS** components)
- **IEC 62443-3-2:2020** (Risk assessment **IACS**)

Software Bill of Materials (**SBOM**)

Lähde: https://kyberturvallisuuskeskus.fi/sites/default/files/media/file/CRA%20valmistaja%20ja%20suuntaa%20antavat%20vaatimukset.pdf
kyberturvallisuuskeskus.fi → Kyberkestävyyssäädös (CRA) → CRA:n valmistajan velvoitteet ja suuntaa antavat vaatimukset standardeissa

Harjoitus

Etsi CRAsta kohta johon liitty Software Bill of Materials (**SBOM**)

Vihje

kyberturvallisuuskeskus.fi → Kyberkestävyyssäädös (CRA) → CRA

kyberturvallisuuskeskus.fi → CRA → CRA:n valmistajan velvoitteet ja suuntaa antavat vaatimukset standardeissa

Harjoituksen eräs ratkaisu

https://kyberturvallisuuskeskus.fi/sites/default/files/media/file/CRA%20valmistaja%20ja%20suuntaa%20antavat%20vaatimukset.pdf

kyberturvallisuuskeskus.fi → Kyberkestävyyssäädös (CRA) → CRA:n valmistajan velvoitteet ja suuntaa antavat vaatimukset standardeissa

TRAFICOM
Liikenne- ja viestintävirasto
Kyberturvallisuuskeskus

Muistio 2 (7)

18.11.2025

Turvallinen oletuskonfiguraatio ja palautus alkuasetuksiin (secure by default)	Liite I, Osa I, 2) b) ne on asetettava saataville markkinoilla oletusarvoisesti tietoturvallisin asetuksin, jolleivät valmistaja ja yrityskäyttäjä ole digitaalisia elementtejä sisältävän räätälöidyn tuotteen osalta sopineet toisin, ja ne on voitava palauttaa alkuperäiseen tilaansa;	ETSI EN 303 645 V2.1.1:2020 (IoT baseline security) ISO/IEC 18031:2011 (Random bit generation, secure default parameters)
SBOM: komponenttien ja haavoittuvuuksien dokumentointi	Liite I, Osa II, 1) tunnistettava ja dokumentoitava digitaalisia elementtejä	EN ISO/IEC 30111:2019 EN ISO/IEC 29147:2020

CRA → Liite I

II osa Haavoittuvuuksien käsittelyä koskevat vaatimukset

Digitaalisia elementtejä sisältävien tuotteiden valmistajien on

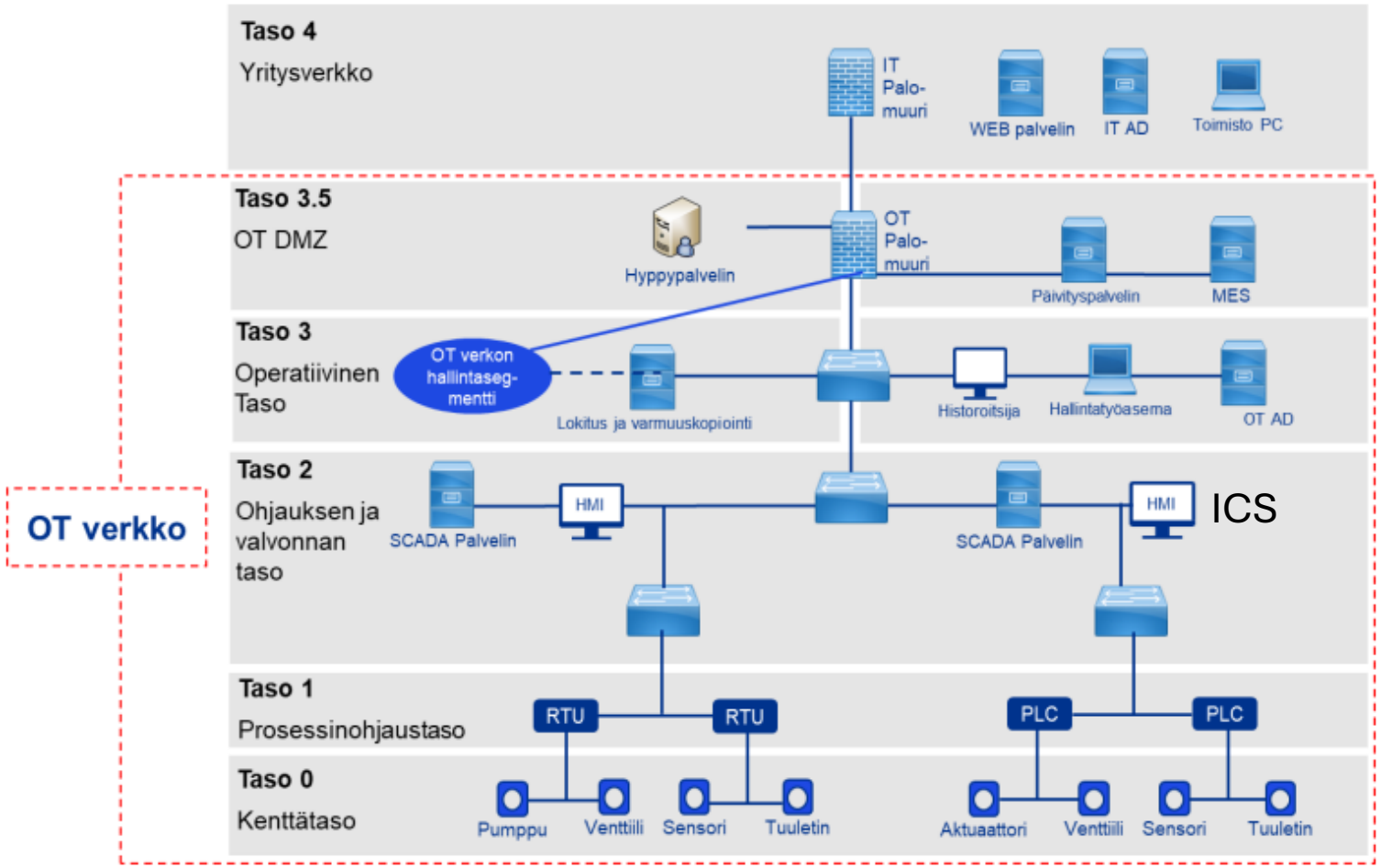
1) tunnistettava ja dokumentoitava digitaalisia elementtejä sisältävään tuotteeseen sisältyvät haavoittuvuudet ja komponentit muun muassa laatimalla vähintään tuotteiden ylimmän tason riippuvuudet kattava ohjelmistojen materiaaliluettelo yleisesti käytetyssä ja koneluettavassa muodossa;

68/81 ELI: http://data.europa.eu/eli/reg/2024/2847/oj

Sisältö

1. Säädökset FI – EU sääntely
2. EUn Kyberkestävyyssäädös (Cyber Resilience Act, CRA)
3. IEC 62443 standardisarja ja kyberturva
4. SBOM (Software Bill Of Materials)

OT verkko (“tuotantoverkko”) - ICS/IACS järjestelmä



ISO/IEC 27001

IEC 62443

Lähde: Artturi Hoffrén - IEC 62443 -SERTIFIKAATTIEN TARVE SUOMALAISISSA YRITYKSISSÄ

OT (Operational technology)
ICS (Industrial Control System, teollisuuden ohjausjärjestelmä
IACS (Industrial Automation and Control System, teollisuuden ohjausjärjestelmä)
SCADA (Supervisory control and data acquisition, valvomo)
HMI (Human Machine Interface, käyttöpaneeli)
PLC (Programmable Logic Controller, ohjelmoitava logiikka) – **RTU** (Remote Terminal Unit)

IEC 62443 -standardisarja

Yleistä

- 62443-1-1 Terminologia, käsitteet ja mallit
- 62443-1-2 Termien ja lyhenteiden yleissanasto
- 62443-1-3 Järjestelmän tietoturvan mittarit
- 62443-1-4 IACSn turvallisuuden elinkaari ja käyttötapaukset

Tointatavat ja käytänteet

- 62443-2-1 Tietoturvaohjelman IACSn omistajille
- 62443-2-2 IACSn tietoturvan hallintajärjestelmän täytäntöönpano-ohjeet
- 62443-2-3 Korjausten hallinta IACS ympäristössä
- 62443-2-4 Tietoturvaohjelman vaatimukset IACS palveluntarjoajille

Järjestelmät

- 62443-3-1 IACSn tietoturvateknologiat
- 62443-3-2 Järjestelmäsuunnittelun tietoturvariskien arviointi
- 62443-3-3 Järjestelmän tietoturvavaatimukset ja turvallisuustasot

Komponentit

- 62443-4-1 Turvallisen tuotekehityksen elinkaaren vaatimukset (**SDL**)
- 62443-4-2 Tekniset turvallisuusvaatimukset IACS komponenteille

ICS (Industrial Control System, Teollisuuden ohjausjärjestelmä)
IACS (Industrial Automation and Control System, Teollisuuden ohjausjärjestelmä)
SDL (Secure Development Life-cycle)

IEC 62443-4-1
Turvallisen tuotekehityksen elinkaaren vaatimukset (**SDL**)

1 – Security Management

Vastuut, prosessit ja jatkuvan parantamisen.

2 – Specification of Security Requirements

Turvallisuusominaisuudet (esim. autentikointi, lokitus, salaus) uhkamallinnus (threat modeling) tuotteen käyttökonteksti (product security context)

3 – Secure by Design

Käsittää turvallisen arkkitehtuurin ja suunnitteluperiaatteet, mm. defense in depth

4 – Secure Implementation

Miten suunnittelussa määritetyt suojausperiaatteet viedään käytäntöön koodauksessa ja toteutuksessa

5 – Security Verification and Validation Testing

täyttääkö tuote määritetyt turvallisuusvaatimukset ja toimiiko se turvallisesti todellisessa käyttöympäristössään

SVV-1: Security requirements testing
Varmistaa, että määritetyt turvallisuusominaisuudet toimivat oikein ja virhetilanteet käsitellään turvallisesti.
SVV-2: Threat mitigation testing
Testataan uhkamallissa tunnistettujen uhkien torjunnan tehokkuus
SVV-3: Vulnerability testing
Fuzzing, tunnetut haavoittuvuudet, hyökkäyspinta-analyysi
SVV-4: Penetration testing
Hyökkäysskenaariot, joissa pyritään murtamaan luottamuksellisuus, eheys ja saatavuus
SVV-5: Independence of testers
Testauksen riippumattomuus tuotteen kehittäjistä eri testauksen vaiheissa

6 – Management of Security-Related Issues

7 – Security Update Management

korjauspäivitysten (patches) hallinnan, testauksen, dokumentoinnin ja julkaisun.

8 – Security Guidelines

Tuotteen mukana toimitettava käyttäjädokumentaatio, joka ohjeistaa:turvalliset asennus- ja konfigurointikäytännöt

Sisältö

1. Säädökset FI – EU sääntely
2. EUn Kyberkestävyyssäädös (Cyber Resilience Act, CRA)
3. IEC 62443 standardisarja ja kyberturva
4. SBOM (Software Bill Of Materials)

Toimitusketju

Security Imperatives: The Cost of Ignorance 🔗

🚨 **Supply Chain Attack Epidemic**

High-profile attacks have demonstrated the devastating impact of compromised dependencies:

- **SolarWinds (2020)**: Compromised build system affected 18,000+ organizations
- **Codecov (2021)**: Bash script modification exposed sensitive data
- **Log4Shell (2021)**: Single vulnerability in Java logging library affected millions of applications
- **ua-parser-js (2021)**: NPM package compromise with cryptocurrency miners

Lähde: https://sbomgenerator.com/learn/what-is-sbom

Kyberrosvot-podcast | Jakso 5 | SolarWinds – Miten aurinkotuuli muuttui myrskyksi

146 views • 2 years ago

DNA Yrityksille

Kyberrosvojen viides jakso kertoo SolarWindsin toimitusketjuhyökkäyksestä. Miten ihmeessä aurinkotuuli muuttui 18 000 ...

https://www.youtube.com/watch?v=w4nm4YNAoZ8

SBOM (Software Bill Of Materials)

Tunnistaa ohjelmistokomponentit ja niiden väliset riippuvuudet

Cyber Resilience Act (CRA) - Kyberkestävyyssäädös

II osa Haavoittuvuuksien käsittelyä koskevat vaatimukset

Digitaalisia elementtejä sisältävien tuotteiden valmistajien on

1) tunnistettava ja dokumentoitava digitaalisia elementtejä sisältävään tuotteeseen sisältyvät haavoittuvuudet ja komponentit muun muassa laatimalla vähintään tuotteiden ylimmän tason riippuvuudet kattava ohjelmistojen materiaaliluettelo yleisesti käytetyssä ja koneluettavassa muodossa;

CRAn soveltamisohje

TRAFICOM
Liikenne- ja viestintävirasto
Kyberturvallisuuskeskus

Muistio

Turvallinen oletuskonfiguraatio ja palautus alkuasetuksiin (secure by default)	Liite I, Osa I, 2) b) ne on asetettava saataville markkinoilla oletusarvoisesti tietoturvallisin asetuksin, jolleivät valmistaja ja yrityskäyttäjä ole digitaalisia elementtejä sisältävän räätälöidyn tuotteen osalta sopineet toisin, ja ne on voitava palauttaa alkuperäiseen tilaansa;	ETSI EN security ISO/IEC genera
SBOM: komponenttien ja haavoittuvuuksien dokumentointi	Liite I, Osa II, 1) tunnistettava ja dokumentoitava digitaalisia elementtejä	EN ISO/ EN ISO/

https://kyberturvallisuuskeskus.fi/sites/default/files/media/file/CRA%20valmistaja%20ja%20suuntaa%20antavat%20vaatimukset.pdf

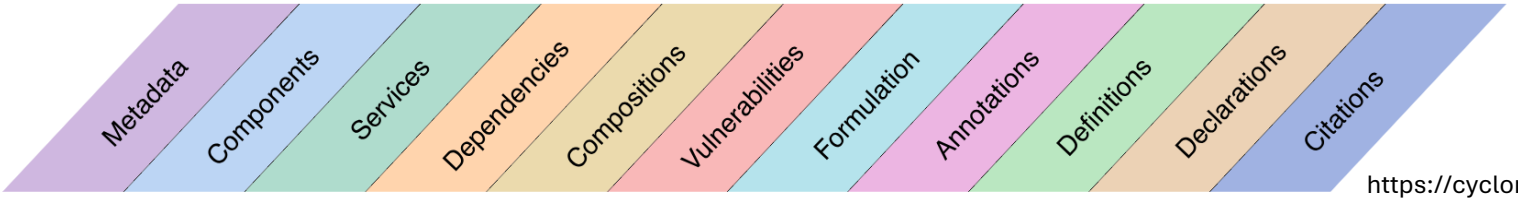
SPDX
ISO/IEC 5962:2021, Linux Foundation

https://github.com/spdx/
https://spdx.dev/

CycloneDX
ECMA-424, OWASP Foundation

https://cyclonedx.org/

- Lisenssien ja komponenttidatan tarkkaan kuvaamiseen
- Molemmat ovat avoimia, yhteisövetosia standardeja
- Molemmat kuvaavat paketit, versiot, riippuvuudet ja metadatan
- Molemmat toimivat koneellisesti luettavina formaatteina (JSON/XML)
- Molempia tukevat työkalut kuten Syft, Grype, Dependency-Track



https://cyclonedx.org/specification/overview/

SPDX vs CycloneDX - mikä on oleellista kenenkä mielestä

1. Viranomainen

II osa Haavoittuvuuksien käsittelyä koskevat vaatimukset

Digitaalisia elementtejä sisältävien tuotteiden valmistajien on

1) tunnistettava ja dokumentoitava digitaalisia elementtejä sisältävään tuotteeseen sisältyvät haavoittuvuudet ja komponentit muun muassa laatimalla vähintään tuotteiden ylimmän tason riippuvuudet kattava ohjelmistojen materiaaliluettelo yleisesti käytetyssä ja koneluettavassa muodossa;

2. Yritys

- Täydellinen komponentti-inventaario (nimi, versio, lisenssi, riippuvuudet) – pakollinen markkinoillepääsyyn 12/2027 alkaen
- perusta haavoittuvuuksien hallinnalle ja päivityksille koko elinkaaren ajan
- Haavoittuvuuksien raportointivelvollisuuden selvitys 9/2026

3. Asiakas

- Lisenssitiedot ja käyttöehdot – varmistaa juridisen reunaehdon ja vältetään lisenssiriskit
- nimi+versio → CVE-kartoitus – mahdollistaa riskien arvioinnin

4. Yrityksen mahdollinen ostaja

- Haavoittuvuuksien nykytila + korjausprosessi
- Lisenssikokonaisuus – juridinen vahingonkorvausriski
- Prosessit: miten SBOM tuotetaan, allekirjoitetaan ja julkaistaan

The European Union Agency for Cybersecurity (ENISA)

2.2.1 SPECIFICATIONS AND FORMAT

We introduce the principal SBOM specifications, explain the data they capture, and assess their suitability for resource constrained manufacturers.

Two primary SBOM formats have emerged as industry standards:

- *SPDX (System Package Data Exchange)*
- *CycloneDX*

Lähde: https://www.enisa.europa.eu/news/call-for-feedback-advancing-software-supply-chain-security-together → SBOM Landscape Analysis

Aspect	SPDX	CycloneDX	SWID Tags
License Focus	★★★★★	★★★	★★
Security Focus	★★★	★★★★★	★★
Tool Ecosystem	★★★★★	★★★★	★★★
Format Variety	★★★★★	★★★★	★★
Enterprise Integration	★★★★	★★★★	★★★★★
Community Adoption	★★★★★	★★★★	★★★
Standardization Maturity	★★★★★	★★★★	★★★★★

Lähde: https://sbomgenerator.com/learn/what-is-sbom
https://opensource.org/licenses

Syft muuntaa riippuvuudet koneluettavaan SBOMiin

- CPE-tunnisteet (esim. cpe:2.3:a:...)
- PURL (Package URL)
- Lisenssitiedot
- Metadata (versio, tyyppi, hash)

Harjoitus

Tee yksittäisestä hakemistosta SBOM, esim. Kali Linux “/usr/bin/”

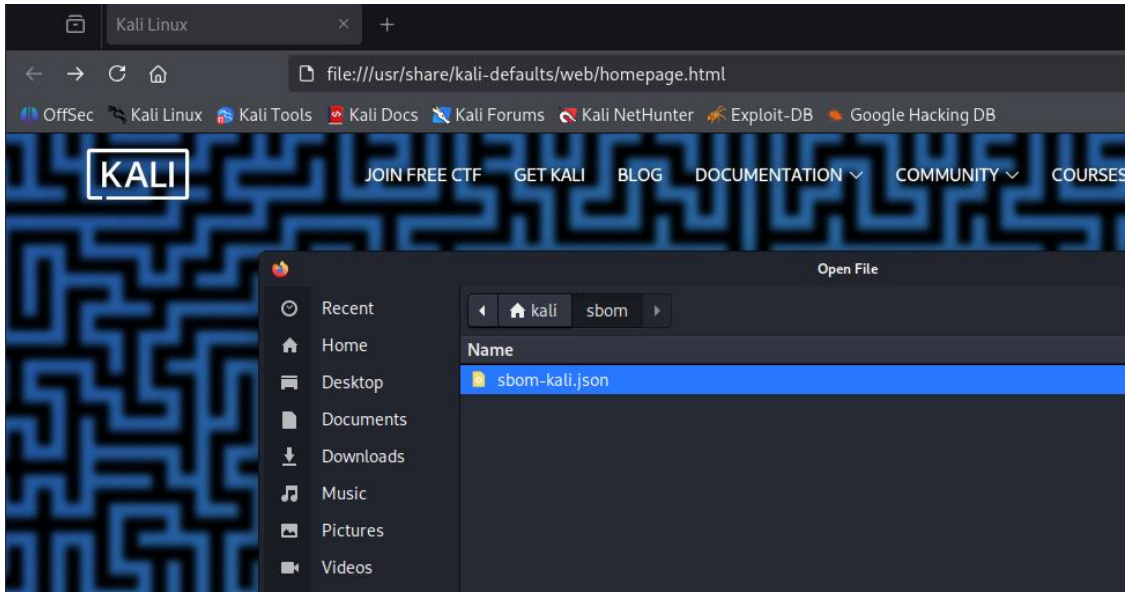
1. Asenna syft jos ei ole jo asennettuna (ohjeet https://github.com/anchore/syft)
curl -sSfL https://get.anchore.io/syft | sudo sh -s -- -b /usr/local/bin

2. Tee Kali linuxiin hakemisto “sbom” ja siirry hakemistoon
mkdir sbom
cd sbom

3. Tee SBOM Kali linuxin /usr/bin hakemistosta ja tallenna se JSON -tiedostoksi
syft /usr/lib/ -o json=sbom-kali.json

Oletuksena syft oma muotoilu sisältäen mahdollisimman paljon tietoa

4. Avaa selaimella tehty SBOM tiedosto **ctrl+o** *sbom-kali.json ja tutki sen rakennetta*



Harjoitus

Yksittäisestä ohjelmasta Kali linux ohjelmasta SBOM esim. “ssh”

1. Selvitä mistä SSH-ohjelma löytyy
which ssh → esim. /usr/bin/ssh

2. Tee SBOM tiedostoon
syft /usr/bin/ssh -o json=sbom-ssh.json

3. Avaa selaimella tehty SBOM tiedosto **ctrl+o** *sbom-ssh.json ja tutki sen rakennetta*

```
importedLibraries:
    0:                                  "libselinux.so.1"
    1:                                  "libgssapi_krb5.so.2"
    2:                                  "libcrypto.so.3"
    3:                                  "libz.so.1"
    4:                                  "libc.so.6"
```

Käytetyt kirjastot

```
elfSecurityFeatures:
    symbolTableStripped:                true
    stackCanary:                        true
    nx:                                 true
    relRO:                              "full"
    pie:                                true
    dso:                                true
    safeStack:                          false
```

Binaryn turvallisuusominaisuuksia

```
used:
    0:                                  "alpm-db-cataloger"
    1:                                  "apk-db-cataloger"
    2:                                  "binary-classifier-cataloger"
    3:                                  "cargo-auditable-binary-cataloger"
    4:                                  "cocoapods-cataloger"
    5:                                  "conan-cataloger"
    6:                                  "conda-meta-cataloger"
    7:                                  "dart-pubspec-cataloger"
```

Mitä “catalogeja” syft käyttää tunnistukseen

Grype

Haavoittuvuusscanneri: konttien kuvat, hakemistot, SBOMit, yksittäiset paketit

Asenna grype, jos ei ole asennettuna jo (ohjeet https://github.com/anchore/grype)
curl -sSfL https://get.anchore.io/grype | sudo sh -s -- -b /usr/local/bin

Harjoitus

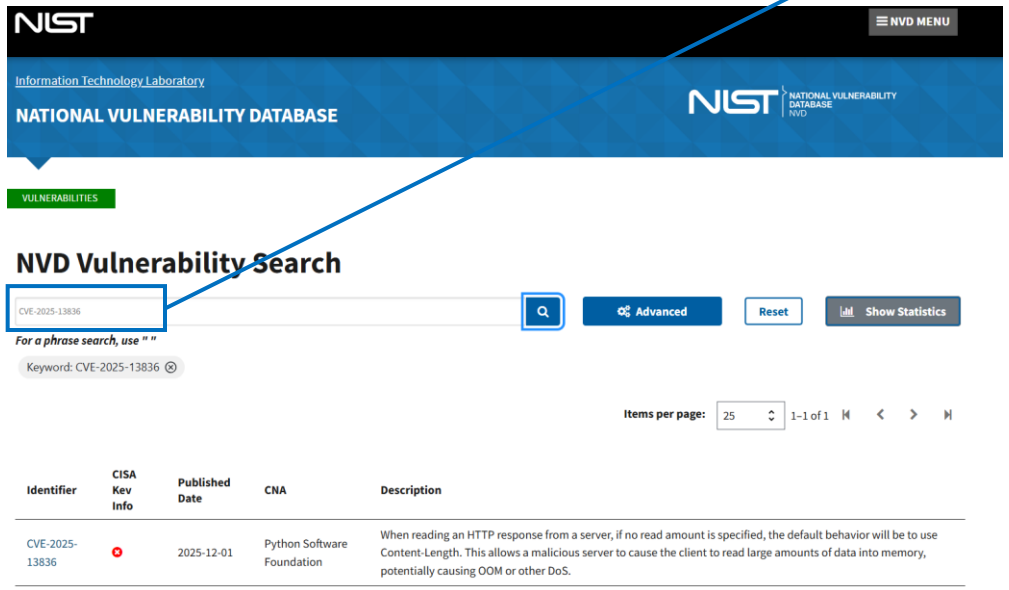
1. Tee haavoittuvuusanalyysi aikaisemmin tehdylle SBOMille *sbom-kali.json*

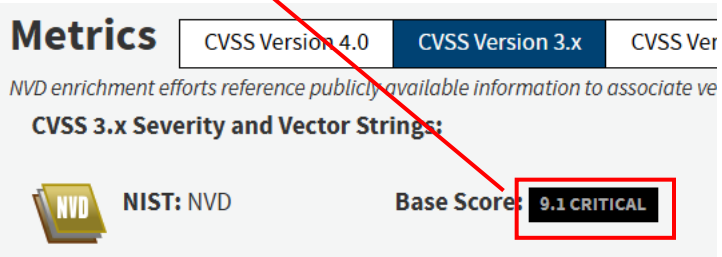
grype sbom:sbom-kali.json

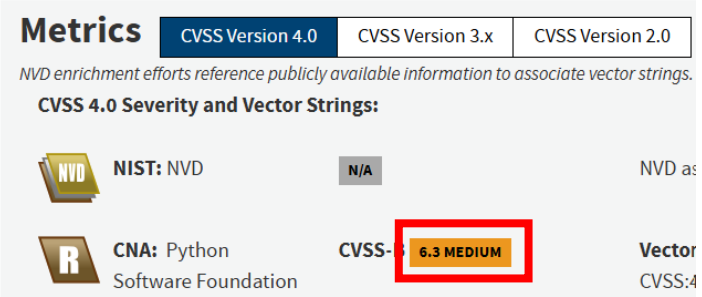
```
└─$ grype sbom:sbom-kali.json
 ✔ Scanned for vulnerabilities     [92 vulnerability matches]
   ├── by severity: 4 critical, 26 high, 48 medium, 14 low, 0 negligible
   └── by status:   87 fixed, 5 not-fixed, 0 ignored [0001]  WARN Unable to determine the OS distribution of some packages. This may result in missing vulnerabilities. You may specify a distro using: --distro <distro>:<version>
NAME            INSTALLED          FIXED IN                                          TYPE       VULNERABILITY        SEVERITY  EPSS           RISK
rexml           3.2.6              3.2.7                                             gem        GHSA-vg3r-rm7w-2xgh  Medium    6.9% (91st)    3.6
rexml           3.2.6              3.3.2                                             gem        GHSA-4xqq-m2hx-25v8  Medium    7.3% (91st)    3.4
rdoc            6.6.2              6.6.3.1                                           gem        GHSA-592j-995h-p23j  Low       2.7% (85th)    1.0
rexml           3.2.6              3.3.9                                             gem        GHSA-2rxp-v6pw-ch6m  Medium    1.3% (78th)    0.8
python-socketio 5.13.0             5.14.0                                            python     GHSA-g8c6-8fjj-2r4m  Medium    1.3% (79th)    0.8
rexml           3.2.6              3.3.6                                             gem        GHSA-vmwr-mc7x-5vc3  High      1.1% (77th)    0.8
cryptography    43.0.0             44.0.1                                            python     GHSA-79v4-65xg-pq4g  Low       1.7% (81st)    0.5
ecdsa           0.19.1                                                               python     GHSA-wj6h-64fc-37mp  High      0.6% (69th)    0.5
rexml           3.2.6              3.3.3                                             gem        GHSA-5866-49gr-22v4  Medium    0.7% (70th)    0.4
ffmpeg          7.1.1              7.1.2                                             binary     CVE-2025-9951        High      0.4% (60th)    0.3
ffmpeg          7.1.1              7.1.2                                             binary     CVE-2025-1594        High      0.4% (57th)    0.3
stdlib          go1.22.6           1.22.7, 1.23.1                                    go-module  CVE-2024-34156       High      0.3% (53rd)    0.2
calendar        8.4.11                                                               binary     CVE-2017-6485        Medium    0.3% (53rd)    0.2
rexml           3.2.6              3.3.3                                             gem        GHSA-r55c-59qm-vjw6  Medium    0.2% (45th)    0.1
calendar        8.4.11             2022-04-28                                        binary     CVE-2022-4455        Medium    0.2% (47th)    0.1
stdlib          go1.22.6           1.22.7, 1.23.1                                    go-module  CVE-2024-34158       High      0.1% (35th)    0.1
fonttools       4.57.0             4.60.2                                            python     GHSA-768j-98cg-p3fv  Medium    0.2% (38th)    < 0.1
python          3.13.7             3.13.11, 3.14.2, 3.15.0                           binary     CVE-2025-12084       Medium    0.2% (39th)    < 0.1
django          4.2.23             4.2.26                                            python     GHSA-frmv-pr5f-9mcr  Critical  < 0.1% (27th)  < 0.1
net-imap        0.4.19             0.4.20                                            gem        GHSA-j3g3-5qv5-52mj  Medium    0.2% (36th)    < 0.1
postgresql      17.5                                                                 binary     CVE-2017-8806        Medium    0.2% (37th)    < 0.1
python          3.13.7             3.13.11, 3.14.1, 3.15.0                           binary     CVE-2025-13836       Critical  < 0.1% (25th)  < 0.1
openjdk         21.0.8+9-Debian-1  1.8.0_472, 8.0.472, 11.0.29, 17.0.17, 21.0.9, ...  binary     CVE-2025-53066       High      < 0.1% (26th)  < 0.1
python          3.13.7                                                               binary     CVE-2024-3220        Low       0.3% (49th)    < 0.1
starlette       0.46.1             0.47.2                                            python     GHSA-2c2j-9gv5-cj73  Medium    0.1% (33rd)    < 0.1
python          3.13.7             3.9.24, 3.10.19, 3.11.14, 3.12.12, 3.13.10, ...   binary     CVE-2025-8291        Medium    0.1% (32nd)    < 0.1
postgresql      17.5               13.22, 14.19, 15.14, 16.10, 17.6                  binary     CVE-2025-8715        High      < 0.1% (22nd)  < 0.1
h2              4.2.0              4.3.0                                             python     GHSA-847f-9342-265h  Medium    0.1% (29th)    < 0.1
openjdk         21.0.8+9-Debian-1  1.8.0_472, 8.0.472, 11.0.29, 17.0.17, 21.0.9, ...  binary     CVE-2025-53057       Medium    < 0.1% (26th)  < 0.1
stdlib          go1.22.6           1.22.11, 1.23.5, 1.24.0-rc.2                      go-module  CVE-2024-45336       Medium    < 0.1% (23rd)  < 0.1
pypdf           5.4.0              6.0.0                                             python     GHSA-7hfw-26vp-jp8m  Medium    < 0.1% (24th)  < 0.1
pypdf           5.4.0              6.1.3                                             python     GHSA-vr63-x8vc-m265  Medium    < 0.1% (24th)  < 0.1
stdlib          go1.22.6           1.23.8, 1.24.2                                    go-module  CVE-2025-22871       Critical  < 0.1% (13th)  < 0.1
```

python 3.13.7 3.13.11, 3.14.1, 3.15.0 binary CVE-2025-13836 Critical < 0.1% (25th) < 0.1

NVD - U.S. government repository of standards based vulnerability management data (https://nvd.nist.gov/)







Harjoitus

1. Lataa web full–stack projekti github.com/jhaimaka → TANSSIPALVELIN_FB
   git clone https://github.com/JHaimaka/TANSSIPALVELIN_FB.git

2. Tee syft ohjelmalla SBOM sekä FRONT (React.js) BACK (Node.js & Atlas MongoDB) osuuksista ***CycloneDX*** *JSON* –muodossa

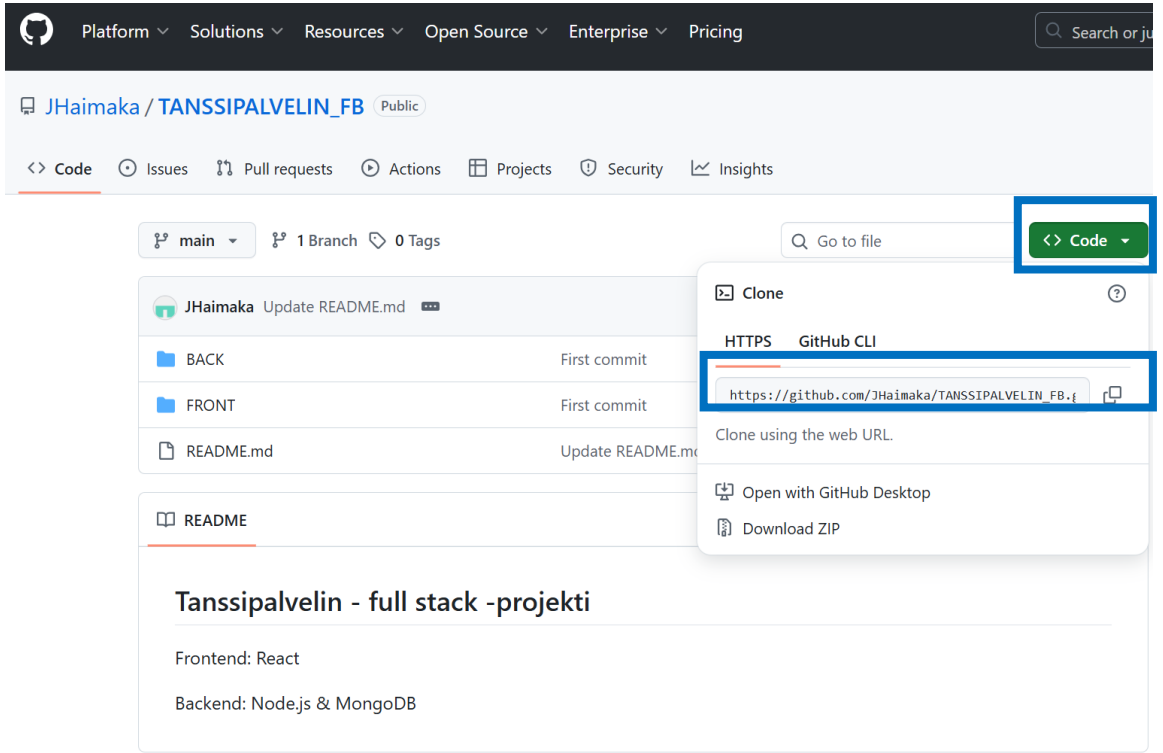
   Vihje: *CycloneDX muodolle kts.* github.com/anchore/syft
   → Multiple output formats
   → Multiple outputs

3. Tee haavoittuvuusanalyysi BACK-komponenteille grype -ohjelmalla

4. Tee haavoittuvuusanalyysi BACK-komponenteille npm –ohjelmalla
   npm audit

```
┌──(kali㉿kali)-[~/sbom/TANSSIPALVELIN_FB/BACK]
└─$ npm audit
# npm audit report

body-parser  <=1.20.3 || 2.0.0-beta.1 - 2.0.2
Severity: high
body-parser vulnerable to denial of service when url encoding is enabled - https://github.com/advisories/GHSA-qwcr-r2
fm-qrc7
Depends on vulnerable versions of qs
fix available via `npm audit fix`
node_modules/body-parser
  express  <=4.21.2 || 5.0.0-alpha.1 - 5.0.1
  Depends on vulnerable versions of body-parser
```



```
└─$ grype sbom:./sbom-back-cdx.json
 ✔ Scanned for vulnerabilities     [14 vulnerability matches]
   ├── by severity: 1 critical, 6 high, 2 medium, 5 low, 0 negligible
NAME             INSTALLED  FIXED IN  TYPE  VULNERABILITY        SEVERITY  EPSS           RISK
mongoose         8.0.3      8.9.5     npm   GHSA-vg7j-7cwx-8wgw  Critical  72.1% (98th)   64.9
mongoose         8.0.3      8.8.3     npm   GHSA-m7xq-9374-9rvx  High      61.2% (98th)   53.0
body-parser      1.20.1     1.20.3    npm   GHSA-qwcr-r2fm-qrc7  High      2.1% (83rd)    1.6
serve-static     1.15.0     1.16.0    npm   GHSA-cm22-4g7w-348p  Low       0.7% (70th)    0.3
tar              6.2.0      6.2.1     npm   GHSA-f5x3-32g6-xq36  Medium    0.5% (63rd)    0.3
qs               6.11.0     6.14.1    npm   GHSA-6rw7-vpxm-498p  High      0.2% (36th)    0.1
path-to-regexp   0.1.7      0.1.12    npm   GHSA-rhx6-c78j-4q9w  High      < 0.1% (25th)  < 0.1
express          4.18.2     4.19.2    npm   GHSA-rv95-896h-c2vc  Medium    0.1% (30th)    < 0.1
path-to-regexp   0.1.7      0.1.10    npm   GHSA-9wv6-86v2-598j  High      < 0.1% (20th)  < 0.1
send             0.18.0     0.19.0    npm   GHSA-m6fv-jmcg-4jfg  Low       0.1% (31st)    < 0.1
express          4.18.2     4.20.0    npm   GHSA-qw6h-vgh9-j6wx  Low       < 0.1% (25th)  < 0.1
cookie           0.5.0      0.7.0     npm   GHSA-pxg6-pf52-xh8x  Low       < 0.1% (24th)  < 0.1
jws              3.2.2      3.2.3     npm   GHSA-869p-cjfg-cm3x  High      < 0.1% (0th)   < 0.1
brace-expansion  1.1.11     1.1.12    npm   GHSA-v6h2-p8h4-qcjw  Low       < 0.1% (4th)   < 0.1
A newer version of grype is available for download: 0.104.3 (installed version is 0.104.2)
```

Tiedostoon

grype sbom:./sbom-back-cdx.json --output json | jq . > back_vuln_report.json

Asenna jq ohjelma tarvittaessa

Vertaa package.json

```
┌──(kali㉿kali)-[~/sbom/TANSSIPALVELIN_FB/BACK]
└─$ cat package.json
{
  "name": "tanssipalvelin_b",
  "version": "1.0.0",
  "description": "Tanssipalvelimen back-end",
  "main": "index.js",
  "scripts": {
    "dev": "nodemon index.js",
    "start": "node index.js",
    "test": "echo \"Error: no test specified\" && exit 1"
  },
  "author": "Jarmo Haimakainen",
  "license": "ISC",
  "dependencies": {
    "bcrypt": "^5.1.1",
    "cors": "^2.8.5",
    "dotenv": "^16.3.1",
    "express": "^4.18.2",
    "jsonwebtoken": "^9.0.2",
    "mongoose": "^8.0.3"
  }
}
```


```
JSON   Raw Data   Headers
Save  Copy  Collapse All  Expand All  Filter JSON
▼ matches:
  ▼ 0:
    ▶ vulnerability:                                  {…}
    ▼ relatedVulnerabilities:
      ▶ 0:                                            {…}
    ▶ matchDetails:                                   […]
    ▶ artifact:                                       {…}
  ▼ 1:
    ▼ vulnerability:
        id:                                           "GHSA-m7xq-9374-9rvx"
        dataSource:                                   "https://github.com/advisories/GHSA-m7xq-9374-9rvx"
        namespace:                                    "github:language:javascript"
        severity:                                     "High"
        urls:                                         []
        description:                                  "Mongoose search injection vulnerability"
      ▼ cvss:
        ▼ 0:
            type:                                     "Secondary"
            version:                                  "3.1"
            vector:                                   "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
          ▼ metrics:
              baseScore:                              9.8
              exploitabilityScore:                    3.9
              impactScore:                            5.9
            vendorMetadata:                           {}
      ▼ epss:
        ▼ 0:
            cve:                                      "CVE-2024-53900"
            epss:                                     0.61214
            percentile:                               0.98237
            date:                                     "2026-01-06"
      ▼ cwes:
        ▼ 0:
            cve:                                      "CVE-2024-53900"
            cwe:                                      "CWE-89"
            source:                                   "134c704f-9b21-4f2e-91b3-4a467353bcc0"
            type:                                     "Secondary"
      ▼ fix:
        ▼ versions:
            0:                                        "8.8.3"
          state:                                      "fixed"
        ▼ available:
          ▼ 0:
              version:                                "8.8.3"
              date:                                   "2024-12-03"
              kind:                                   "first-observed"
        advisories:                                   []
        risk:                                         52.95011000000001
    ▶ relatedVulnerabilities:                         […]
    ▶ matchDetails:                                   […]
```